

Politique de sessions et de jetons de l'Hôtel Palmier d'Or

TP 4 · Sessions, jetons et mots de passe



Référence temporelle pour ce TP : jeudi 7 mai 2026 à 09:00:00 UTC.

Audience attendue pour l'API partenaire : partenaire-resa-api.



Jetons JWT

- ◆ Les jetons d'accès de l'API partenaire utilisent HS256 et le secret d'essai « secret-d-exemple » sert seulement à vérifier la signature.
- ◆ Tout jeton qui annonce un autre algorithme ou qui ne valide pas sa signature est rejeté.
- ◆ La durée de validité d'un jeton d'accès ne doit jamais dépasser 20 minutes. Une durée égale à 20 minutes reste conforme.



Sessions

- ◆ Après une connexion réussie, l'identifiant de session doit être régénéré avant les requêtes authentifiées.
- ◆ Une déconnexion invalide immédiatement la session côté serveur.
- ◆ Après plus de 15 minutes d'inactivité, la requête suivante doit être refusée et l'utilisateur doit se reconnecter.



Mots de passe

- ◆ Sont conformes : Argon2id, bcrypt avec un coût au moins égal à 12, PBKDF2-SHA256 avec au moins 600000 itérations.
- ◆ Ne sont pas conformes : MD5, SHA-1, SHA-256 sans sel, bcrypt avec un coût de 10 ou 11, PBKDF2-SHA256 sous 600000 itérations.
- ◆ Ordre du plus faible au plus robuste pour ce TP : MD5, SHA-1, SHA-256 sans sel, PBKDF2-SHA256 sous 600000, bcrypt coût 10 ou 11, PBKDF2-SHA256 conforme, bcrypt coût 12 ou plus, Argon2id.
- ◆ Longueur minimale d'un mot de passe : 12 caractères.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite.